

Cyber Tabletop Exercise

Deepfake Vishing Against the Help Desk for Privileged Reset

Scenario source: STIX bundle provided by user

Exercise type: Facilitated tabletop exercise

Sector: Financial services / banking

Duration: 60–90 minutes

Audience: Executive, operational, and technical stakeholders

Classification: Internal use only

1. Purpose

This tabletop exercise is designed to test the organization's ability to detect, validate, escalate, contain, and recover from a socially engineered privileged-access event in which an adversary uses voice impersonation and urgency to pressure the internal service desk into resetting multifactor authentication (MFA) for a privileged user.

The exercise is based on the supplied STIX scenario describing a **deepfake vishing attempt against a privileged access workflow**, involving a **crime-syndicate-style threat actor using voice impersonation**, a **help-desk MFA reset attack pattern**, and response measures focused on **strict identity proofing** and **rapid privileged-account containment**.

2. Exercise Objectives

By the end of the exercise, participants should be able to:

- Evaluate whether current help-desk identity verification controls are sufficient for privileged-user requests.
 - Test decision-making under pressure when a caller claims executive authority and urgent business impact.
 - Assess escalation thresholds from service desk to IAM, SOC, incident management, fraud, and crisis leadership.
 - Validate the organization's ability to rapidly contain a potentially compromised privileged account.
 - Examine dependencies across downstream systems, remote access, administrative tooling, and sensitive data stores.
 - Review internal and external communication expectations, including executive communications and regulatory considerations.
 - Identify improvement actions for privileged reset workflows, voice-channel verification, and post-incident governance.
-

3. Suggested Participants

Executive / Crisis Leadership

- Crisis management lead
- CIO / CISO delegate
- Business executive sponsor
- Communications lead
- Legal / compliance / privacy representative

Operational

- IT service desk manager
- Identity and access management (IAM) lead
- HR / executive support representative
- Business operations lead
- Risk management representative

Technical

- Security operations center (SOC)
- Incident response lead
- Privileged access management (PAM) administrator
- Directory / cloud identity administrator
- Endpoint / infrastructure engineering representative

Exercise Support

- Facilitator
 - Scribe / observer
-

4. Scope and Assumptions

In Scope

- Help-desk handling of privileged reset requests
- Voice-channel identity validation
- MFA reset and account recovery controls
- Privileged account monitoring and containment
- Internal escalation and crisis coordination
- Technical scoping of downstream exposure
- Communications and regulatory considerations

Out of Scope

- Detailed malware reverse engineering
- Full forensic acquisition procedures

- Third-party litigation strategy
- Public attribution of the threat actor

Assumptions

- The organization operates an internal service desk that supports privileged-user access workflows.
 - The targeted account has elevated access to critical banking systems, administration tooling, or security-sensitive platforms.
 - The exercise assumes participants respond using their current policies, runbooks, authorities, and escalation channels.
 - Where documentation is incomplete, participants should state reasonable assumptions.
-

5. Rules of Engagement

- Real-world incidents take priority over the exercise.
 - This is a no-fault discussion exercise intended to improve resilience.
 - There are no perfect answers; focus on roles, decisions, dependencies, and gaps.
 - Treat the scenario as credible and unfolding in real time.
 - The facilitator may introduce additional facts if discussion stalls or key decision points are missed.
-

6. Scenario Overview

A threat actor places a call to the internal help desk, sounding convincingly like a senior executive. The caller claims to be traveling, locked out, and unable to complete an urgent business action without immediate assistance. The caller pressures the analyst to bypass or weaken standard identity checks and complete a privileged MFA reset.

Shortly after the reset, anomalous activity is observed involving the privileged account, including a login from an unusual location and signs of session activity inconsistent with the executive's known behavior. The organization must quickly determine whether the request was fraudulent, whether the account has been compromised, what systems may now be exposed, and what containment actions are justified.

The scenario tests trust boundaries in human support workflows, especially where urgency, perceived authority, and executive pressure collide with security controls.

7. Threat Context

Threat Actor

A socially engineered fraud actor using voice impersonation techniques to gain privileged access through the service desk.

Core Attack Theme

- Impersonation of a senior leader
- Exploitation of help-desk trust and urgency
- Bypass of standard identity proofing
- Abuse of privileged access after MFA reset

Why This Matters

Voice impersonation and deepfake-assisted vishing can defeat informal or experience-based identity judgments. Where privileged accounts are involved, a single reset error can create immediate enterprise-wide risk affecting identity infrastructure, administration platforms, communications systems, and regulated business services.

8. Exercise Structure

This exercise is divided into four injects. Each inject includes:

- Situation update
- Information known at that stage
- Discussion questions
- Expected actions
- Facilitator notes

Recommended timing:

- Inject 1: 10 minutes
 - Inject 2: 15 minutes
 - Inject 3: 15 minutes
 - Inject 4: 10 minutes
 - Final debrief: 10–15 minutes
-

9. Timeline and Injects

Inject 1 – Executive Voice Call to Help Desk

Simulated time: 08:45

Incident stage: Initial contact / social engineering attempt

Scenario narrative

A caller sounding like a senior executive contacts the internal service desk. The caller states they are traveling, have a critical meeting within the hour, and are locked out after losing access to their MFA

method. The caller is impatient, references internal names and recent travel details, and insists that normal reset procedures be bypassed because of urgency and seniority.

The analyst recognizes the voice as sounding highly similar to the executive and feels pressure to resolve the matter immediately.

Information provided to participants

- The request involves a privileged or highly sensitive account.
- The caller claims inability to complete standard MFA verification.
- The caller demands exception handling due to business urgency.
- No independent confirmation has yet been performed through another trusted channel.
- The help-desk analyst is escalating informally to a supervisor for guidance.

Discussion questions

- What should the help desk do immediately?
- What controls apply specifically to privileged-user resets?
- Is there a no-exception process for high-risk identity recovery events?
- What trusted out-of-band verification channels are available?
- Who has authority to approve or deny a privileged MFA reset?
- At what point should the event be treated as suspected social engineering rather than a normal support request?
- How should the analyst document the interaction and preserve evidence from the call?

Expected participant actions

- Refuse any bypass of established privileged reset procedures.
- Require strong step-up identity proofing through an approved out-of-band process.
- Escalate to IAM / PAM and the security function for a high-risk access event.
- Record details of the call, timing, callback number, claimed business justification, and analyst observations.
- Notify the executive's office or designated support channel through a trusted method to validate the request.
- Flag the event as a potential phishing attempt even if the identity remains unconfirmed.

Facilitator notes

Push participants on whether process discipline survives executive pressure. Watch for informal workarounds such as manager approval by chat, recognition of the voice alone, or reliance on knowledge-based questions that may already be exposed.

Inject 2 – Reset Completed and Privileged Session Anomaly

Simulated time: 10:15

Incident stage: Suspected account compromise / initial access

Scenario narrative

Despite policy, the reset was completed after the caller became more insistent and cited business disruption. Within a short period, monitoring detects a successful privileged login from an unusual geographic location and at an unusual time for the purported executive. There are indications the account may have active sessions against one or more sensitive systems.

The organization must now determine whether to disable the account immediately, revoke sessions, rotate credentials, and assess downstream impact.

Information provided to participants

- A privileged login is observed from an unusual location after the reset.
- The login pattern does not align with the executive's normal behavior.
- It is not yet confirmed whether the real executive initiated the call.
- One or more downstream systems may already have been accessed.
- Business stakeholders warn that disabling the account could interrupt important approvals or operations.

Discussion questions

- What threshold of evidence is enough to declare suspected privileged-account compromise?
- What is the exact order of containment actions?
- Do you disable the account, revoke tokens, terminate sessions, and rotate credentials immediately?
- What systems, logs, and identity providers must be queried first?
- What additional accounts, shared secrets, emergency access paths, or delegated privileges may be at risk?
- Who needs to be informed within the first 15–30 minutes?
- How do you balance evidence preservation with the need to stop active access?

Expected participant actions

- Classify the event as suspected compromise of a privileged identity.
- Disable or restrict the account and revoke active sessions.
- Reset credentials and reissue secure access through a controlled process.
- Review identity provider, VPN, PAM, SSO, administrative, and endpoint logs.
- Scope whether any approvals, changes, or privileged actions occurred after the reset.
- Launch incident response coordination and assign an incident commander.
- Notify business, legal, compliance, and relevant executive stakeholders.

Facilitator notes

Encourage participants to articulate exact authorities and timelines. A common weakness is uncertainty about who can disable an executive or privileged account when business operations may be affected.

Inject 3 – Downstream Exposure and Business Impact Decisions

Simulated time: 11:30

Incident stage: Discovery / containment expansion

Scenario narrative

The investigation shows the privileged account accessed administrative resources and attempted to enumerate connected systems shortly after login. It is not yet clear whether any data was viewed, changed, or exported. Several teams now report dependency concerns: privileged approvals are pending, a sensitive production change window is open, and operations leaders want to know whether the event is contained.

Rumors begin spreading internally that a senior executive account was compromised through the help desk.

Information provided to participants

- Logs suggest access to one or more administrative consoles.
- No confirmed data exfiltration is known yet.
- There is concern that additional tokens, API keys, or delegated permissions may have been exposed.
- Business operations may be delayed if access remains suspended.
- Internal stakeholders are requesting frequent updates.

Discussion questions

- What are the most important scoping questions now?
- Which downstream systems should be reviewed first?
- Do you widen containment beyond the single account?
- How do you handle related privileged accounts, break-glass accounts, or shared admin workflows?
- What internal communications should be issued, and to whom?
- When does this become a crisis-management issue rather than only a security incident?
- What legal, privacy, regulatory, or fraud considerations should be raised at this stage?

Expected participant actions

- Expand scoping to all systems reachable by the compromised identity.
- Review privileged actions, session recordings, configuration changes, and access logs.
- Validate whether other users were socially engineered or targeted similarly.
- Brief leadership on containment status, business impact, and uncertainty.
- Engage legal, privacy, and compliance for notification decision support.
- Preserve evidence from help-desk systems, call metadata, recordings, and authentication logs.
- Prepare contingency workarounds for disrupted privileged business processes.

Facilitator notes

Probe whether participants treat the help desk as a critical control boundary. Good responses should include call-record review, process-failure analysis, and broader hunt activity for similar reset attempts.

Inject 4 – Stabilization, Recovery, and Follow-On Actions

Simulated time: 15:00

Incident stage: Recovery / post-incident governance

Scenario narrative

The organization has contained the privileged account and found no evidence of sustained persistence beyond the initial access window. However, the investigation confirms that the help-desk process was defeated by a convincing voice impersonation attempt and weak exception handling. Leadership requests a clear view of lessons learned, required control changes, and any notification obligations.

Information provided to participants

- The compromised access path has been disabled.
- The organization is assessing whether any downstream actions require remediation.
- Control weaknesses in service-desk identity proofing are confirmed.
- Senior management wants assurance that similar attacks cannot succeed again.

Discussion questions

- What are the immediate recovery actions before normal access is restored?
- What short-term compensating controls should be implemented within 24–72 hours?
- What long-term improvements are required across the service desk, IAM, PAM, and security monitoring?
- What should be included in the executive readout or post-incident report?
- What policies, scripts, training, or approval authorities need revision?
- Are there regulatory, audit, or customer-trust implications that require follow-up?

Expected participant actions

- Validate recovery of the affected account and any related systems.
- Confirm credential rotation, token invalidation, and closure of any temporary access paths.
- Implement an immediate no-exception rule for privileged reset workflows.
- Introduce or strengthen out-of-band verification requirements.
- Review help-desk training, scripting, supervisor escalation, and fraud awareness.
- Update detection logic for high-risk reset events followed by anomalous logins.
- Produce a post-incident report with decisions, timeline, impacts, gaps, and remediation actions.

Facilitator notes

This stage should not end with “training only.” Look for layered improvements spanning people, process, and technology.

10. Cross-Functional Decision Points

Participants should explicitly address:

- Who can authorize privileged account recovery or denial in urgent executive scenarios?
 - What constitutes sufficient proof for suspected compromise?
 - When must the SOC or incident response team be engaged?
 - Who can suspend business-critical privileged access despite operational impact?
 - When do legal, privacy, compliance, and communications become mandatory participants?
 - What triggers formal crisis-management activation?
-

11. Expected Technical and Business Impacts

Technical Impacts

- Unauthorized privileged access
- Exposure of administrative consoles or identity platforms
- Risk to downstream systems, tokens, and delegated access
- Loss of trust in help-desk recovery workflow
- Need for emergency credential rotation and broader log review

Business Impacts

- Delayed executive approvals or privileged operations
 - Increased operational friction for urgent support cases
 - Potential regulatory scrutiny if privileged workflows are inadequate
 - Reputational concern if executive impersonation succeeds
 - Internal confidence impact across service desk and leadership teams
-

12. Facilitator Prompts

Use these prompts if discussion slows:

- “What exact evidence do you need before disabling the account?”
 - “What if the real executive is unreachable for two hours?”
 - “Which downstream systems would concern you most first?”
 - “What if a second, similar reset request is received during the incident?”
 - “How do you distinguish convenience from authorized exception handling?”
 - “Which team owns the call-record review and process-failure analysis?”
-

13. Evaluation Criteria

Assess participant performance against the following:

- Prompt recognition of social engineering risk
 - Consistent application of privileged identity-proofing controls
 - Clear ownership for escalation and containment decisions
 - Timely privileged-account containment and scoping
 - Cross-functional coordination across security, IAM, service desk, business, and governance teams
 - Quality of executive communication and incident documentation
 - Practical remediation actions that reduce repeat risk
-

14. Debrief and Lessons Learned

Debrief Questions

- What decisions were made quickly and effectively?
- Where did uncertainty delay action?
- Which teams lacked clarity on authority, ownership, or sequence?
- What dependencies were discovered in privileged access workflows?
- What evidence sources were hardest to obtain quickly?
- What policy, training, or tooling changes would most reduce risk?

Likely Improvement Themes

- No-exception privileged reset process
 - Strong out-of-band verification for sensitive identity recovery
 - Tighter service-desk supervisor escalation rules
 - Better correlation of reset events with anomalous login telemetry
 - PAM / IAM integration with high-risk alerting
 - Executive awareness that security controls cannot be waived verbally
-

15. Recommended Follow-On Actions

Immediate

- Enforce step-up identity proofing for privileged users.
- Suspend informal exceptions for voice-only reset requests.
- Add alerting for MFA reset followed by unusual-location login.
- Review recent privileged reset activity for similar patterns.

Near-Term

- Update help-desk scripts and decision trees.

- Conduct targeted training on vishing and deepfake-assisted impersonation.
- Validate incident runbooks for privileged account rapid containment.
- Improve preservation of call metadata and recordings for investigations.

Strategic

- Reassess privileged access governance and emergency access design.
 - Introduce phishing-resistant authentication and stronger recovery controls where possible.
 - Reduce dependence on human judgment alone for high-risk identity recovery.
 - Test the revised process through a follow-up tabletop or control validation exercise.
-

16. MITRE ATT&CK Mapping

The following ATT&CK techniques are relevant to the scenario narrative and the attack behavior represented in the STIX bundle:

Initial Access / Credential Abuse / Valid Account Use

- **T1078 – Valid Accounts**

The adversary seeks to obtain and use a legitimate privileged account after defeating the recovery process.

Credential Access / Social Engineering

- **T1656 – Impersonation**

The actor impersonates a senior executive to manipulate the help desk.

- **T1586 – Compromise Accounts** (*conceptually adjacent depending on interpretation of the exercise outcome*)

The scenario centers on fraudulent takeover of an existing account rather than creation of a new one.

Defense Evasion / Privilege-Related Abuse

- **T1078.004 – Valid Accounts: Cloud Accounts** or **T1078.003 – Valid Accounts: Local Accounts**

Use the applicable sub-technique depending on the organization's identity platform and where the privileged account resides.

Discovery / Post-Compromise Scoping

- **T1087 – Account Discovery**

Relevant if the compromised session is used to enumerate identities or privileged relationships.

- **T1018 – Remote System Discovery**

Relevant if the attacker uses the newly obtained privileged access to identify connected systems.

Collection / Impact Considerations

- **T1213 – Data from Information Repositories**

Relevant if the adversary reaches administrative or business repositories accessible through the compromised account.

ATT&CK Tactics Reflected

- Initial Access
- Credential Access
- Defense Evasion
- Discovery
- Collection

Note: The STIX bundle directly describes a voice-impersonation-based social engineering attempt to force an MFA reset for privileged access, then a post-reset anomalous privileged login. The exact downstream ATT&CK sub-techniques should be finalized based on the technologies in scope during exercise customization.

17. Appendix – Source Scenario Elements Interpreted from STIX

This exercise was generated from a STIX bundle containing:

- An organization in the **financial-services** sector
- A **threat actor** using voice impersonation
- An **attack pattern** focused on socially engineering the help desk into resetting MFA for privileged access
- An **incident** describing a deepfake vishing attempt against the privileged-access workflow
- Two explicit **notes/injects**:
 - Executive voice call pressuring the help desk to bypass MFA reset procedures
 - Privileged session anomaly after the reset from an unusual location
- Two **courses of action**:
 - Strict service-desk identity proofing for privileged users
 - Privileged account rapid containment runbook

This document expands those elements into a facilitation-ready tabletop exercise while preserving scenario intent.